

Security+ 4.3 · Penetration Testing

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.3 — Penetration Testing (6:21) · [vídeo original](#) · [YouTube](#)

Pentest: simula ataque pra EXPLODIR falha real e mostrar o impacto. ROE (rules of engagement) define: alvo, janela, técnica, não-quebrar. Responsible disclosure: reporta pro vendor ANTES de publicar. Tipo: white/black/grey box.

Highlights que a prova cobra

- ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest
- White-box: com acesso total; black-box: sem nada
- Responsible disclosure: reporta pro vendor antes de publicar

Dicas de prova

- 'agreement on what the pentester can and cannot do'=ROE

Cenário clássico: 'pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest...

2. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'White-box: com acesso total; black-box: sem nada'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: White-box: com acesso total; black-box: sem nada...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Responsible disclosure: reporta pro vendor antes de publicar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Responsible disclosure: reporta pro vendor antes de publicar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'agreement on what the pentester can and cannot do'=ROE'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'agreement on what the pentester can and cannot do'=ROE...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'White-box: com acesso total; black-box: sem nada'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: White-box: com acesso total; black-box: sem nada...

8. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: 'Responsible disclosure: reporta pro vendor antes de publicar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Responsible disclosure: reporta pro vendor antes de publicar...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "agreement on what the pentester can and cannot do'=ROE'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'agreement on what the pentester can and cannot do'=ROE...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Penetration Testing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.3), um analista avalia o seguinte requisito técnico: "pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) D — Implementar a solução correspondente: ROE (rules of engagement): o que PODE e o o .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest. As demais alternativas configuram violaç
- 2) B — Implementar a solução correspondente: White-box: com acesso total; black-box: se.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): White-box: com acesso total; black-box: sem nada. As demais alternativas configuram violações graves de conformid
- 3) B — Implementar a solução correspondente: Responsible disclosure: reporta pro vendor.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): Responsible disclosure: reporta pro vendor antes de publicar. As demais alternativas configuram violações graves
- 4) B — Implementar a solução correspondente: 'agreement on what the pentester can and c.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): 'agreement on what the pentester can and cannot do'=ROE. As demais alternativas configuram violações graves de co
- 5) B — Implementar a solução correspondente: 'pentester combinou atacar só o IP 10.0.0..** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): 'pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE.. As demais alternativas configuram violaç
- 6) A — Implementar a solução correspondente: ROE (rules of engagement): o que PODE e o o .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): ROE (rules of engagement): o que PODE e o que NÃO PODE fazer no pentest. As demais alternativas configuram violaç
- 7) D — Implementar a solução correspondente: White-box: com acesso total; black-box: se.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): White-box: com acesso total; black-box: sem nada. As demais alternativas configuram violações graves de conformid
- 8) C — Implementar a solução correspondente: Responsible disclosure: reporta pro vendor.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): Responsible disclosure: reporta pro vendor antes de publicar. As demais alternativas configuram violações graves
- 9) A — Implementar a solução correspondente: 'agreement on what the pentester can and c.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): 'agreement on what the pentester can and cannot do'=ROE. As demais alternativas configuram violações graves de co
- 10) C — Implementar a solução correspondente: 'pentester combinou atacar só o IP 10.0.0..** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.3 (Penetration Testing): 'pentester combinou atacar só o IP 10.0.0.5 nas janelas definidas'=ROE.. As demais alternativas configuram violaç

